Q1

4 請問下列哪兩項陳述是正確的？

- [x] 當組織聲稱符合 ISO/IEC 27001 時，排除第 4 至 10 條中指定的任何要求是不可接受的。
- [x] 當組織聲稱符合 ISO/IEC 27001 時，有理由排除附件 A 中指定的任何控制措施是可以接受的。
- [ ] 當組織聲稱符合 ISO/IEC 27001 時，有理由排除附件 A 中指定的任何控制措施是不可接受的。
- [ ] 當組織聲稱符合 ISO/IEC 27001 時，排除第 4 至 10 條中指定的任何要求是可以接受的。

得分: 1出1

Q2



- [x] Training staff
- [ ] Organising changes
- [x] Providing ICT assets
- [ ] Identifying risks
- [ ] Setting objectives
- [x] Retaining documentation

Q3

測試名稱: ISMS ISO_IEC 27001 Lead Auditor practice

Section 1 | Section 2 | Section 3 | Section 4

3 以下選項顯示第三方稽核中涉及的關鍵措施。然而，它們的順序並不正確。請依據進行第三方稽核時應的順序，在表格中進行排序。

這些階段將發生在驗證申請後。

1.	
2.	
3.	
4.	
5.	
6.	

要完成序列，請按一下要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，將選項拖曳到適當的空白部分。

進行稽核　文件審查　申請驗證　審查驗證申請書　任命稽核組長　頒發證書

下一個

3 以下選項顯示第三方稽核中涉及的關鍵措施。然而，它們的順序並不正確。請依據進行第三方稽核時應的順序，在表格中進行排序。

這些階段將發生在驗證申請後。

1.	✔ 申請驗證
2.	✔ 審查驗證申請書
3.	✔ 任命稽核組長
4.	✔ 文件審查
5.	✔ 進行稽核
6.	✔ 頒發證書

要完成序列，請按一下要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，將選項拖曳到適當的空白部分。

我的答案　實際答案

Q4

測試名稱: ISMS ISO_IEC 27001 Lead Auditor practice

Section 1 | Section 2 | S

4 在 ISO 19011 的前後環節中，請從下列選擇一個與第二方稽核的相關的目的？

- 批准外部提供者的組織。
- 確證外部提供者的流程
- 評估外部提供者的管理系統。
- 驗證外部提供者的產品與服務。

下一個

測試名稱: ISMS ISO_IEC 27001 Lead Auditor practice

Section 1 | Section 2 | Secti

4 在 ISO 19011 的前後環節中，請從下列選擇一個與第二方稽核的相關的目的？

- 批准外部提供者的組織。
- 確證外部提供者的流程
- 評估外部提供者的管理系統。
- 驗證外部提供者的產品與服務。

下一個

Q5

測試名稱: ISMS ISO_IEC 27001 Lead Auditor practice

Section 1 | Section

5 根據 ISO/IEC 27000 中提出的術語和定義，下列哪一項有關風險的陳述是正確的？

- ○ 風險處理可能會導致新的風險產生
- ○ 風險對關鍵績效指標的有不確定的影響
- ○ 剩餘風險是應用風險處理之前的風險程度。
- ○ 識別風險是評估風險重要性的過程。

下一個 >

5 根據 ISO/IEC 27000 中提出的術語和定義，下列哪一項有關風險的陳述是正確的？

- ☐ 剩餘風險是應用風險處理之前的風險程度。
- ☐ 識別風險是評估風險重要性的過程。
- ✔ 風險處理可能會導致新的風險產生
- ☐ 風險對關鍵績效指標的有不確定的影響

得分: 1出1

Q6

測試名稱: ISMS ISO_IEC 27001 Lead Auditor practice

Section 1 | Section 2

6 通常下列哪兩項稽核相關活動會與 ISMS第二方稽核有相關連結？

- ☐ 將稽核準則限制在受稽核方的政策、過程和程序。
- ☐ 將稽核結果與你的驗證機構進行溝通
- ☐ 稽核完成後，將會決定是否推薦 ISO 驗證。
- ☐ 告知受稽核方若對稽核進行感到不滿意，他們有權利向其稽核員註冊的機構投訴。
- ☐ 使用提供者合約，作為主要的稽核準則
- ☐ 稽核小組有位認證機構稽核員，負責審查稽核小組成員的表現

下一個 >

6 通常下列哪兩項稽核相關活動會與 ISMS第二方稽核有相關連結？

- ☐ 稽核小組有位認證機構稽核員，負責審查稽核小組成員的表現
- ✔ 使用提供者合約，作為主要的稽核準則
- ☐ 將稽核結果與你的驗證機構進行溝通
- ☐ 告知受稽核方若對稽核進行感到不滿意，他們有權利向其稽核員註冊的機構投訴。
- ☐ 稽核完成後，將會決定是否推薦 ISO 驗證。
- ✔ 將稽核準則限制在受稽核方的政策、過程和程序。

得分: 2出2

Q7

測試名稱: ISMS ISO_IEC 27001 Lead Auditor pra

7 請從下列選擇三項適用於描述「稽核範圍」？

- [ ] 滿足法規要求事項的能力
- [ ] 記錄結果
- [ ] 受稽核的過程
- [ ] 評估符合性
- [ ] 稽核界限
- [ ] 可實現的結果

下一個 ❯

測試名稱: ISMS ISO_IEC 27001 Lead Auditor pra

7 請從下列選擇三項適用於描述「稽核範圍」？

- [x] 滿足法規要求事項的能力
- [ ] 記錄結果
- [x] 受稽核的過程
- [ ] 評估符合性
- [x] 稽核界限
- [ ] 可實現的結果

下一個 ❯

Q8

測試名稱: ISMS ISO_IEC 27001 Lead Auditor practice 1 | Section 2 | Section 3 | Section 4 | Sec

8 因為稽核方式的不同，在稽核過程中，可以與受稽核方的代表有人員互動關係，也可以是沒有互動關係。請問下列哪六種稽核方式是沒有人員互動的？

- ☐ 準備查檢表。
- ☐ 實地考察工作場所。
- ☐ 進行訪談。
- ☐ 現場稽核前，審查受稽核方所提供的文件。
- ☐ 透過即時視訊來觀察工作的執行情況。
- ☐ 分析結果。
- ☐ 檢查是否遵循當地主管機關要求的相關法規。
- ☐ 在受稽核方參與下完成查檢表。
- ☐ 抽樣（例如:產品抽樣）。

- ☑ 準備查檢表。
- ☐ 實地考察工作場所。
- ☐ 進行訪談。
- ☑ 現場稽核前，審查受稽核方所提供的文件。
- ☑ 透過即時視訊來觀察工作的執行情況。
- ☑ 分析結果。
- ☑ 檢查是否遵循當地主管機關要求的相關法規。
- ☐ 在受稽核方參與下完成查檢表。
- ☑ 抽樣（例如:產品抽樣）。

Q9

測試名稱: ISMS ISO_IEC 27001 Lead Auditor prac

9 請從下列選擇三項與「稽核準則」相關的描述？

- [ ] 國際標準。
- [ ] 確認管理系統的範圍
- [ ] 識別改進機會。
- [ ] 管理政策。
- [ ] 法規要求事項。
- [ ] 按時完成稽核

下一個 >

- [x] 國際標準。
- [ ] 確認管理系統的範圍
- [ ] 識別改進機會。
- [x] 管理政策。
- [x] 法規要求事項。
- [ ] 按時完成稽核

Q10

LEADING QUALITY SINCE 1919

測試名稱: ISMS ISO_IEC 27001 Lead Auditor practice 1 | Section 2 | Section 3 | Section 4 | Section

10 ISO 19011 要求得確定每次稽核與稽核方案的相關風險。在以遠距(視訊)稽核的情況下，請配對過程與其相關風險。

要填寫表格，請按一下要填寫的空白部分以將其反白顯示為紅色，然後從下面的選項中按一下適用的文字。或者，將每個選項拖曳到相應的空白部分。

風險	流程
網路連線失敗	
稽核小組整體能力不足	
未能設定相關的稽核目標、範圍和準則	
未能建立抽樣相關的規範	
允許的稽核時間和資訊科技相關資源都不足	
稽核員和受稽核方之間缺乏協調	

資源分配。 | 稽核規劃。 | 溝通過程。 | 稽核活動 | 抽樣過程。

選擇稽核小組的成員。

下一個

風險	流程
網路連線失敗	✔ 稽核活動
稽核小組整體能力不足	✔ 選擇稽核小組的成員。
未能設定相關的稽核目標、範圍和準則	✔ 稽核規劃。
未能建立抽樣相關的規範	✔ 抽樣過程。
允許的稽核時間和資訊科技相關資源都不足	✔ 資源分配。
稽核員和受稽核方之間缺乏協調	✔ 溝通過程。

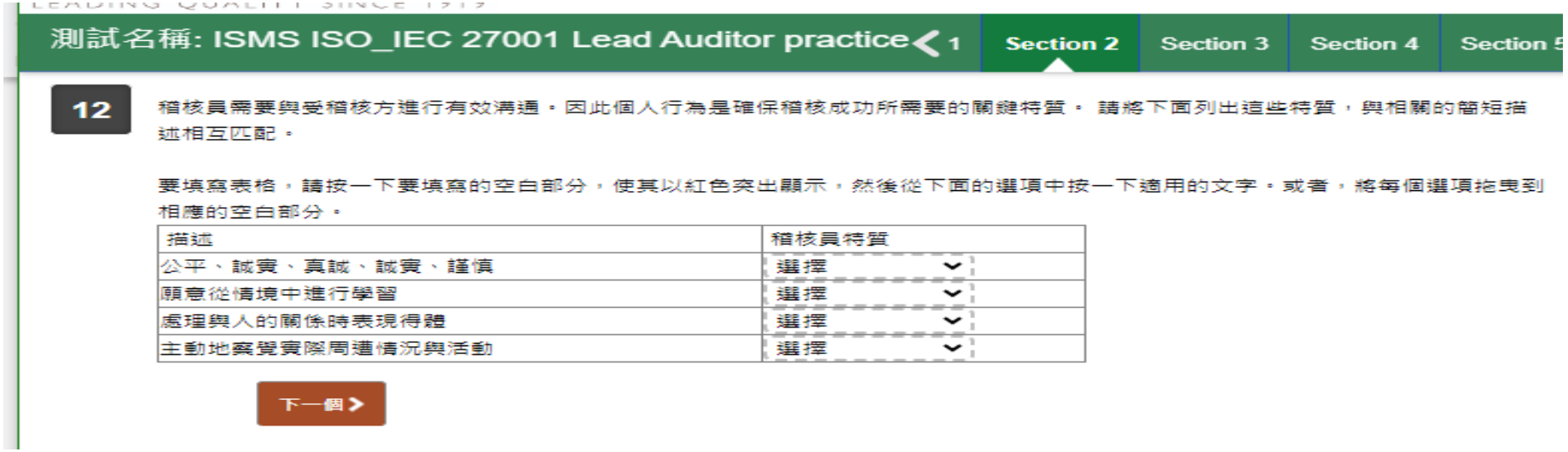
Q11



措施

1. 確定資訊來源
2. 透過適當的抽樣收集
3. 稽核證據
4. 根據稽核準則進行評估
5. 稽核發現
6. 審閱
7. 稽核結論

Q12



描述	稽核員特質
公平、誠實、真誠、誠實、謹慎	具道德觀 ✓
願意從情境中進行學習	願意改進 ✓
處理與人的關係時表現得體	具外交手腕 ✓
主動地察覺實際周遭情況與活動	觀察敏銳 ✓

Q13

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

13 審查下列**哪三項**陳述是**正確**的：

- ☐ 在遠距稽核期間，應提倡受稽核方參予者的網路攝影機應維持在啟用狀態。
- ☐ 在遠距稽核前進行技術檢查，將可以提高稽核效率與有效性。
- ☐ 具備執行現場稽核能力的稽核員，不需要額外進行遠距稽核相關訓練，因為所需的技能並沒有顯著的差異。
- ☐ 分配給第三方稽核的天數的決定，是取決於受稽核方適當的時間點。
- ☐ 選擇現場、遠端稽核或合併使用，應考慮過往績效和先前稽核結果。
- ☐ 出於保密和安全考慮，遠端稽核期間的螢幕共享，是稽核團隊審查受稽核方文件的唯一方法

下一個

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

13 審查下列**哪三項**陳述是**正確**的：

- ☑ ☐ 在遠距稽核期間，應提倡受稽核方參予者的網路攝影機應維持在啟用狀態。
- ☑ ☐ 在遠距稽核前進行技術檢查，將可以提高稽核效率與有效性。
- ☐ 具備執行現場稽核能力的稽核員，不需要額外進行遠距稽核相關訓練，因為所需的技能並沒有顯著的差異。
- ☐ 分配給第三方稽核的天數的決定，是取決於受稽核方適當的時間點。
- ☑ ☐ 選擇現場、遠端稽核或合併使用，應考慮過往績效和先前稽核結果。
- ☐ 出於保密和安全考慮，遠端稽核期間的螢幕共享，是稽核團隊審查受稽核方文件的唯一方法

下一個

Q14

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

14 以下**哪三個**選項，是稽核過程中，使用稽核抽樣計畫的相關**缺點**？

- ☐ 與稽核員現場感受相違背。
- ☐ 有效實施稽核計畫。
- ☐ 加強對稽核結論的信心。
- ☐ 可能會錯過關鍵議題。
- ☐ 可以重複使用該抽樣計劃進行稽核，且無需審查。
- ☐ 展現對 ISMS 具有準確的理解。

下一個

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

14 以下**哪三個**選項，是稽核過程中，使用稽核抽樣計畫的相關**缺點**？

- ☑ 與稽核員現場感受相違背。
- ☐ 有效實施稽核計畫。
- ☐ 加強對稽核結論的信心。
- ☑ 可能會錯過關鍵議題。
- ☑ 可以重複使用該抽樣計劃進行稽核，且無需審查。
- ☐ 展現對 ISMS 具有準確的理解。

下一個

Q15

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

15 第二階段稽核的啟始會議上，受稽核方組織的執行長邀請稽核團隊觀看 45 分鐘關於公司的新影片。
請舉出稽核組長不應該做出下列**哪三項**回應？

- ☐ 建議執行長稽核小組，必須遵守先前商定稽核計畫中的時間表。
- ☐ 通知執行長稽核小組同意其要求
- ☐ 說明稽核小組決定將稍後觀看。
- ☐ 建議觀看影片的前五分鐘來了解其內容
- ☐ 表明稽核組長將在稽核結束會議後留下來，其代表稽核團隊觀看影片。
- ☐ 告知執行長可能有機會在當天結束時觀看該影片

下一個 >

15 第二階段稽核的啟始會議上，受稽核方組織的執行長邀請稽核團隊觀看 45 分鐘關於公司的新影片。
請舉出稽核組長不應該做出下列哪三項回應？

- ✔ 表明稽核組長將在稽核結束會議後留下來，其代表稽核團隊觀看影片。
- ✔ 通知執行長稽核小組同意其要求
- ✔ 說明稽核小組決定將稍後觀看。
- ☐ 建議執行長稽核小組，必須遵守先前商定稽核計畫中的時間表。
- ☐ 建議觀看影片的前五分鐘來了解其內容
- ☐ 告知執行長可能有機會在當天結束時觀看該影片

Q16

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

16 請問下列**哪三個**選項，對於「使用稽核查檢表」的描述是錯的

- [ ] 記錄證據相關細節
- [ ] 限制訪談的對象。
- [ ] 確保稽核計畫得到實施
- [ ] 非必要時不改變該查核清單
- [ ] 每次稽核都使用相同查檢表且無需審查
- [ ] 確保相關的稽核軌跡被遵循

下一個

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

16 請問下列**哪三個**選項，對於「使用稽核查檢表」的描述是錯的

- [ ] 記錄證據相關細節
- [x] 限制訪談的對象。
- [ ] 確保稽核計畫得到實施
- [x] 非必要時不改變該查核清單
- [x] 每次稽核都使用相同查檢表且無需審查
- [ ] 確保相關的稽核軌跡被遵循

下一個

Q17

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

17 進行文件化資訊審查為規劃稽核的一部分，請從下列選擇一項最能描述其目的選項。

- ○ 揭露記錄的系統是否不符合其稽核準則，並收集證據與 ISMS 管理階層進行訪談。
- ○ 查證文化見資訊與稽核準則的相關符合性，並收集資訊以支援稽核活動。
- ○ 根據稽核準則，確定有紀錄的文件系統的不符合性，並收集資訊以編制稽核報告。
- ○ 確證有記錄的系統是否符合稽核準則，並收集資訊以支援稽核發現。

下一個 >

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

17 進行文件化資訊審查為規劃稽核的一部分，請從下列選擇一項最能描述其目的選項。

- ○ 揭露記錄的系統是否不符合其稽核準則，並收集證據與 ISMS 管理階層進行訪談。
- ○ 查證文化見資訊與稽核準則的相關符合性，並收集資訊以支援稽核活動。
- ○ 根據稽核準則，確定有紀錄的文件系統的不符合性，並收集資訊以編制稽核報告。
- ○ 確證有記錄的系統是否符合稽核準則，並收集資訊以支援稽核發現。

下一個 >

Q18

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

18 請從下列選項中，選擇一個「指派稽核組長」之目的的**最佳**描述。

- ○ 控制稽核小組，確保稽核小組的行為符合實踐行為守則。
- ○ 運用所需的知識和技能來組織稽核團隊，創造出有意義的稽核報告。
- ○ 對於稽核團隊管理並且提供領導力，促進稽核高效率且有效地進行著。
- ○ 提供卓越的知識和技能，向稽核團隊展現領導力，並協助稽核取得效率高且有效的結果。
- ○ 為稽核團隊提供卓越知識和技能的重點，以在稽核中取得高績效。
- ○ 運用紀律技能來管理稽核團隊和受稽核方，確保稽核工作有效率並且有效。

ISMS ISO_IEC 270... 1 | Section 2 | **Section 3** | Section 4

18 請從下列選項中，選擇一個「指派稽核組長」之目的的**最佳**描述。

- ○ 控制稽核小組，確保稽核小組的行為符合實踐行為守則。
- ○ 運用所需的知識和技能來組織稽核團隊，創造出有意義的稽核報告。
- ✓ ○ 對於稽核團隊管理並且提供領導力，促進稽核高效率且有效地進行著。
- ○ 提供卓越的知識和技能，向稽核團隊展現領導力，並協助稽核取得效率高且有效的結果。
- ○ 為稽核團隊提供卓越知識和技能的重點，以在稽核中取得高績效。
- ○ 運用紀律技能來管理稽核團隊和受稽核方，確保稽核工作有效率並且有效。

Q19

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

19 你的組織目前正在尋求 ISO/IEC 27001:2022 驗證。你剛獲得 ISMS 內部稽核員的資格。 ICT 經理希望利用你新獲得的知識來協助他了解組織的前後環節。 他已經完成初步工作，根據他對第 4 條文中標準要求的解釋來確定組織的前後環節但希望稽核員能審查，來了解他的解釋是否正確。

以下**哪三項**他的觀察是**正確**的？

- ☐ 相關議題，是指未來可能發生的事件，其影響可以透過應用控制來降低。
- ☐ 要求組織持續改善資訊安全管理系統。
- ☐ 大多數組織選擇文件化其資訊安全管理系統的範圍
- ☐ 由利害關係者而不是組織來決定哪些要求與資訊安全管理系統相關
- ☐ 資訊安全管理系統的範圍決定其邊界和適用性，像是哪些內容構成系統的一部分，以及哪些內容不構成系統的一部分。
- ☐ 「相關」議題是那些適用組織目的且能夠影響組織資訊安全管理系統的預期結果的議題。
- ☐ 「所需過程及其交互作用」的確定，可參考風險思維。。
- ☐ 組織需要隨著時間的變化，監控相關方的需求和期望。

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

19 你的組織目前正在尋求 ISO/IEC 27001:2022 驗證。你剛獲得 ISMS 內部稽核員的資格。 ICT 經理希望利用你新獲得的知識來協助他了解組織的前後環節。 他已經完成初步工作，根據他對第 4 條文中標準要求的解釋來確定組織的前後環節但希望稽核員能審查，來了解他的解釋是否正確。

以下**哪三項**他的觀察是**正確**的？

- ☐ 相關議題，是指未來可能發生的事件，其影響可以透過應用控制來降低。
- ☑ 要求組織持續改善資訊安全管理系統。
- ☐ 大多數組織選擇文件化其資訊安全管理系統的範圍
- ☐ 由利害關係者而不是組織來決定哪些要求與資訊安全管理系統相關
- ☑ 資訊安全管理系統的範圍決定其邊界和適用性，像是哪些內容構成系統的一部分，以及哪些內容不構成系統的一部分。
- ☑ 「相關」議題是那些適用組織目的且能夠影響組織資訊安全管理系統的預期結果的議題。
- ☐ 「所需過程及其交互作用」的確定，可參考風險思維。。
- ☐ 組織需要隨著時間的變化，監控相關方的需求和期望。

Q20

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

20 你的組織目前正在尋求 ISO/IEC 27001:2022 驗證。你剛剛獲得內部 ISMS 稽核員資格，ICT 經理希望能利用你新獲得的知識來協助產生文件化資訊，以支援 ISMS 的運作且證明其為有效性的實施。ICT 經理對記錄的資訊做出以下陳述。請問下列**哪四個**選項是正確的？

- ☐ 組織必須制定適當處置過程來處理冗餘的文件化資訊
- ☐ 資訊安全政策、資訊安全目標和管理審查結果必須作為文件化資訊提供。
- ☐ 定期審查和更新組織的風險評鑑流程是「保留」文件化資訊的例子。
- ☐ 術語「記錄」可用於描述組織保留的文件化資訊以證明符合性
- ☐ 文件化資訊必須寫在紙上可作為稽核證據
- ☐ 必須保留文件化資訊以證明資訊安全管理系統的變更已按計畫進行
- ☐ 「文件化資訊」一詞不適用於包含該資訊的媒介
- ☐ ISO/IEC 27001:2022 允許組織確定是否有必要保留證明員工適任性的文件化訊資訊。

---

20 你的組織目前正在尋求 ISO/IEC 27001:2022 驗證。你剛剛獲得內部 ISMS 稽核員資格，ICT 經理希望能利用你新獲得的知識來協助產生文件化資訊，以支援 ISMS 的運作且證明其為有效性的實施。ICT 經理對記錄的資訊做出以下陳述。請問下列**哪四個**選項是正確的？

- ✔ 術語「記錄」可用於描述組織保留的文件化資訊以證明符合性
- ✔ 定期審查和更新組織的風險評鑑流程是「保留」文件化資訊的例子。
- ✔ 資訊安全政策、資訊安全目標和管理審查結果必須作為文件化資訊提供。
- ✔ 組織必須制定適當處置過程來處理冗餘的文件化資訊
- ☐ 文件化資訊必須寫在紙上可作為稽核證據
- ☐ 必須保留文件化資訊以證明資訊安全管理系統的變更已按計畫進行
- ☐ ISO/IEC 27001:2022 允許組織確定是否有必要保留證明員工適任性的文件化訊資訊。
- ☐ 「文件化資訊」一詞不適用於包含該資訊的媒介

得分: 2出2

Q21

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

21 你是稽核小組組長，負責對網路服務供應商進行第三方追查稽核。培訓中的稽核員與你聯繫，要求你確認下列**哪四個**與其 ISO/IEC 27001:2022 管理系統相關的 ISMS 議題。

- ☐ 地方政府正在考慮減少向該組織支付的研發補助金
- ☐ 據傳主要競爭對手正在城鎮另一邊建造最先進的資料中心
- ☐ 最近的一項調查顯示，未來 5 年內對網路服務的需求將增加 300%
- ☐ 預計匯率將大幅上漲。這將使吸引海外的客戶變得更加困難。
- ☐ 由於支付系統軟體故障，外部提供商未收到付款。
- ☐ 自從執行長進期離職到其他地方擔任更高薪職位以來，該組織目前沒有分配擔任資訊安全職務的人事
- ☐ 監控進出現場的閉路電視系統目前尚未運作。
- ☐ 服務等級同意書回應的時間經常被錯過

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

21 你是稽核小組組長，負責對網路服務供應商進行第三方追查稽核。培訓中的稽核員與你聯繫，要求你確認下列**哪四個**與其 ISO/IEC 27001:2022 管理系統相關的 ISMS 議題。

- ☐ 地方政府正在考慮減少向該組織支付的研發補助金
- ☐ 據傳主要競爭對手正在城鎮另一邊建造最先進的資料中心
- ☐ 最近的一項調查顯示，未來 5 年內對網路服務的需求將增加 300%
- ☐ 預計匯率將大幅上漲。這將使吸引海外的客戶變得更加困難。
- ☑ 由於支付系統軟體故障，外部提供商未收到付款。
- ☑ 自從執行長進期離職到其他地方擔任更高薪職位以來，該組織目前沒有分配擔任資訊安全職務的人事
- ☑ 監控進出現場的閉路電視系統目前尚未運作。
- ☑ 服務等級同意書回應的時間經常被錯過

Q22

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

22 你是位經驗豐富的 ISMS 稽核員，正在對網路服務供應商進行第三方追查稽核。 你正在審查與今年早些時間，發生的三起資訊安全事故相關的文件化資訊。
你發現在三起資訊安全事故中，組織都受到拒絕服務相關攻擊，導致客戶在全天大部分時間裡都無法使用網路。並且，在三起資訊安全事故中，都發現組織未能使病毒檢測軟體保持最新狀態。

根據上述情況，以下**哪三項**控制措施將成為你稽核的重點？

- ☐ 控制措施 8.23 - 網頁過濾。
- ☐ 控制措施 8.9 – 組態管理。
- ☐ 控制措施 7.3 – 保全辦公室、房間和設施
- ☐ 控制措施 7.5 - 防範實體和環境威脅。
- ☐ 控制措施 8.7 - 防範惡意軟體。
- ☐ 控制措施 8.8 - 技術脆弱性管理。
- ☐ 控制措施 8.13 - 資訊備份。
- ☐ 控制措施 5.27 – 由資訊安全事件中學習。

下一個

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

22 你是位經驗豐富的 ISMS 稽核員，正在對網路服務供應商進行第三方追查稽核。 你正在審查與今年早些時間，發生的三起資訊安全事故相關的文件化資訊。
你發現在三起資訊安全事故中，組織都受到拒絕服務相關攻擊，導致客戶在全天大部分時間裡都無法使用網路。並且，在三起資訊安全事故中，都發現組織未能使病毒檢測軟體保持最新狀態。

根據上述情況，以下**哪三項**控制措施將成為你稽核的重點？

- ☐ 控制措施 8.23 - 網頁過濾。
- ☐ 控制措施 8.9 – 組態管理。
- ☐ 控制措施 7.3 – 保全辦公室、房間和設施
- ☐ 控制措施 7.5 - 防範實體和環境威脅。
- ☑ 控制措施 8.7 - 防範惡意軟體。
- ☑ 控制措施 8.8 - 技術脆弱性管理。
- ☐ 控制措施 8.13 - 資訊備份。
- ☑ 控制措施 5.27 – 由資訊安全事件中學習。

下一個

Q23

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

23 你是位經驗豐富的 ISMS 稽核組長。培訓中的稽核員正在協助你使用 ISO/IEC 27001:2022 作為稽核準則進行第三方追查稽核。你要求培訓中的稽核員評估該組織持續改進的方法。培訓中的稽核員已經進行希望與你討論他的調查結果。

您認為他的以下**哪四項**建議，可以作為不符合性之發現？

- ☐ 我認為我們應該針對第 9 條績效評估提出不符合性，因為沒有證據表明組織正在使用監控和測量來支持持續改進
- ☐ 我認為我們應該針對第 9.3.2 條管理評審輸入提出不符合性，因為所有管理評審會議都沒有討論持續改進。
- ☐ 我認為我們應該針對第 5.1 條領導力和承諾提出不符合性，因為沒有證據表明高階管理階層促進了持續改進。
- ☐ 我認為我們應該針對第 7.3 條認知提出不符合性，因為個人不知道自己在實現持續改進中的作用。
- ☐ 我認為我們應該針對第 10.1 條持續改進提出不符合性，因為該組織在過去 12 個月內，沒有證明其產品和服務發生任何變化。
- ☐ 我認為我們應該針對第 9.2 條內部稽核提出不符合性，因為稽核員沒有提出改進機會來改進 ISMS。
- ☐ 我認為我們應該針對第 6.1.1 條提出不符合性，因為組織沒有利用其對問題和相關要求的理解，來確定與持續改善相關的風險和機會。
- ☐ 我認為我們應該針對 9.3 管理評審提出不符合性，因為組織沒有考慮客戶的回饋。

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

23 你是位經驗豐富的 ISMS 稽核組長。培訓中的稽核員正在協助你使用 ISO/IEC 27001:2022 作為稽核準則進行第三方追查稽核。你要求培訓中的稽核員評估該組織持續改進的方法。培訓中的稽核員已經進行希望與你討論他的調查結果。

您認為他的以下**哪四項**建議，可以作為不符合性之發現？

- ☐ 我認為我們應該針對第 9 條績效評估提出不符合性，因為沒有證據表明組織正在使用監控和測量來支持持續改進
- ☑ ☐ 我認為我們應該針對第 9.3.2 條管理評審輸入提出不符合性，因為所有管理評審會議都沒有討論持續改進。
- ☑ ☐ 我認為我們應該針對第 5.1 條領導力和承諾提出不符合性，因為沒有證據表明高階管理階層促進了持續改進。
- ☐ 我認為我們應該針對第 7.3 條認知提出不符合性，因為個人不知道自己在實現持續改進中的作用。
- ☐ 我認為我們應該針對第 10.1 條持續改進提出不符合性，因為該組織在過去 12 個月內，沒有證明其產品和服務發生任何變化。
- ☐ 我認為我們應該針對第 9.2 條內部稽核提出不符合性，因為稽核員沒有提出改進機會來改進 ISMS。
- ☑ ☐ 我認為我們應該針對第 6.1.1 條提出不符合性，因為組織沒有利用其對問題和相關要求的理解，來確定與持續改善相關的風險和機會。
- ☑ ☐ 我認為我們應該針對 9.3 管理評審提出不符合性，因為組織沒有考慮客戶的回饋。

Q24

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

24 你是位經驗豐富的 ISMS 稽核組長，指導稽核員進行訓練。
培訓中的稽核員問您為什麼以「有計劃的方式」進行資訊安全管理系統的變更很重要。

請你選擇下列**哪四個**選項，是你適合的回應？

- ☐ 它允許規劃部門監督轉型過程。
- ☐ 它確保創建並遵循詳細說明變更的書面計畫。
- ☐ 它識別潛在問題，並允許制定處理問題的策略。
- ☐ 它確保了有適當資源，可使用在進行中所需要的變更。
- ☐ 它提供了識別改進機會，以及變更帶來的風險與機會。
- ☐ 這使得降低向客戶提供產品或服務時受到不利影響的可能性。
- ☐ 它確保最高管理階層始終參與指導變更過程。
- ☐ 它確保一切會按計畫進行，並且更改時不會出現錯誤。

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

24 你是位經驗豐富的 ISMS 稽核組長，指導稽核員進行訓練。
培訓中的稽核員問您為什麼以「有計劃的方式」進行資訊安全管理系統的變更很重要。

請你選擇下列**哪四個**選項，是你適合的回應？

- ☐ 它允許規劃部門監督轉型過程。
- ☐ 它確保創建並遵循詳細說明變更的書面計畫。
- ☑ 它識別潛在問題，並允許制定處理問題的策略。
- ☑ 它確保了有適當資源，可使用在進行中所需要的變更。
- ☑ 它提供了識別改進機會，以及變更帶來的風險與機會。
- ☑ 這使得降低向客戶提供產品或服務時受到不利影響的可能性。
- ☐ 它確保最高管理階層始終參與指導變更過程。
- ☐ 它確保一切會按計畫進行，並且更改時不會出現錯誤。

Q25

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

25 你是位經驗豐富的 ISMS 稽核組長。培訓中的稽核員正在協助你使用 ISO/IEC 27001:2022 作為稽核準則進行第三方追查稽核。你已要求他們評估組織的規劃方法（第 6 條）。他們已進行調查且想要討論調查結果。 下列哪**兩個**建議是**正確**的？

- ☐ 認為我們應該針對第 6.1.2 條文資訊安全風險管理提出不符合性，因為該組織已確認其從未審查過其資訊安全風險標準。
- ☐ 認為我們應該針對第 6.3 條文變更之規畫提出不符合性，因為該組織最近引入新的採購訂單處理系統，但並沒有文件資訊化其實施計畫
- ☐ 認為我們應該針對第 6.1.3 條文資訊安全風險處理提出不符合性，因為除了附錄 A 中規定的控制措施之外，該組織還實施了自己的控制措施。
- ☐ 認為我們應該針對第 8.1 條文運作之規劃及控制提出不符合性，因為沒有證據表明組織使用第 6 條文的措施證明，輸入已建立的措施作為其 ISMS 流程準則。
- ☐ 認為我們應該針對第 6.1.2 條文資訊安全風險評鑑提出不符合性，因為該組織僅將最高管理階層成員辨別為風險擁有者。
- ☐ 認為我們應該針對第 6.2 條文資訊安全目標及其達成之規劃提出不符合性，因為組織的 6 個目標中有 2 個是受監視的而不是量測的。

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

25 你是位經驗豐富的 ISMS 稽核組長。培訓中的稽核員正在協助你使用 ISO/IEC 27001:2022 作為稽核準則進行第三方追查稽核。你已要求他們評估組織的規劃方法（第 6 條）。他們已進行調查且想要討論調查結果。 下列哪**兩個**建議是**正確**的？

- ☑ 認為我們應該針對第 6.1.2 條文資訊安全風險管理提出不符合性，因為該組織已確認其從未審查過其資訊安全風險標準。
- ☐ 認為我們應該針對第 6.3 條文變更之規畫提出不符合性，因為該組織最近引入新的採購訂單處理系統，但並沒有文件資訊化其實施計畫
- ☐ 認為我們應該針對第 6.1.3 條文資訊安全風險處理提出不符合性，因為除了附錄 A 中規定的控制措施之外，該組織還實施了自己的控制措施。
- ☑ 認為我們應該針對第 8.1 條文運作之規劃及控制提出不符合性，因為沒有證據表明組織使用第 6 條文的措施證明，輸入已建立的措施作為其 ISMS 流程準則。
- ☐ 認為我們應該針對第 6.1.2 條文資訊安全風險評鑑提出不符合性，因為該組織僅將最高管理階層成員辨別為風險擁有者。
- ☐ 認為我們應該針對第 6.2 條文資訊安全目標及其達成之規劃提出不符合性，因為組織的 6 個目標中有 2 個是受監視的而不是量測的。

Q26

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

26 你是一位正在培訓中的稽核員，協助稽核團隊使用 ISO/IEC 27001:2022 作為稽核標準進行第三方追查稽核。你已被要求評估組織實體控制的有效性，目前正在審查你將參與的稽核計畫相關部分。
你已辨識將執行的八項活動，但稽核組長在審查這些活動時，決定只有三項活動與附件 A 中的實體控制相關。請問以下**哪三個**選項與附件 A 實體控制有相關？

- ☐ 13:00 至 14:00 – 檢視與安全區域工作相關的安全量測，特別是給客戶資料、數據集和裝卸區。檢查先前資料的提供記錄，以及過程是否實際上運行。
- ☐ 09:45 至 10:30 – 訪談數據中心經理有關容量管理的問題。 如何根據目前和預期的容量需求，監控和調整資源的水平？
- ☐ 09:15 至 09:45 – 拜訪數據中心 1 ，隨機挑選其中 3 處辦公室。確保這些辦公室受到適當保護，防止未經授權的訪問。如果辦公室無人使用，請確保桌子和螢幕保持淨空。
- ☐ 14:00 至 15:00 – 訪談技術經理後，透過抽樣確認資訊服務、使用者和資訊系統在客戶網路中有適當隔離。
- ☐ 10:30 至 11:30 – 拜訪 1 號數據中心的閉路電視監控辦公室。查看攝影機覆蓋的範圍和閉路電視的登入日誌。檢查閉路電視日誌與門禁系統日誌確保結果是一致的。檢查是否有任何「尾隨」的證據。
- ☐ 15:30 至 16:00 – 審查組織使用的訓練相關資料，以提高對其資訊安全政策和程序的良好認知。檢查線上訓練產品的最新版本。
- ☐ 15:00 至 15:30 – 訪談選定的程式設計師，來確定其開發工具和軟體庫的使用性。檢查他們是否只使用已授權產品。
- ☐ 11:30 至 12:00 – 訪談人事經理有關遠距工作的相關問題。確定適當的安全措施，以保護組織場所以外的資訊存取、處理或儲存。

62% 25/40 字体 下一個 提交

計畫相關部分。
你已辨識將執行的八項活動，但稽核組長在審查這些活動時，決定只有三項活動與附件 A 中的實體控制相關。請問以下哪三個選項與附件 A 實體控制有相關？

- ✔ 09:15 至 09:45 – 拜訪數據中心 1 ，隨機挑選其中 3 處辦公室。確保這些辦公室受到適當保護，防止未經授權的訪問。如果辦公室無人使用，請確保桌子和螢幕保持淨空。
- ☐ 09:45 至 10:30 – 訪談數據中心經理有關容量管理的問題。 如何根據目前和預期的容量需求，監控和調整資源的水平？
- ✔ 10:30 至 11:30 – 拜訪 1 號數據中心的閉路電視監控辦公室。查看攝影機覆蓋的範圍和閉路電視的登入日誌。檢查閉路電視日誌與門禁系統日誌確保結果是一致的。檢查是否有任何「尾隨」的證據。
- ☐ 11:30 至 12:00 – 訪談人事經理有關遠距工作的相關問題。確定適當的安全措施，以保護組織場所以外的資訊存取、處理或儲存。
- ✔ 13:00 至 14:00 – 檢視與安全區域工作相關的安全量測，特別是給客戶資料、數據集和裝卸區。檢查先前資料的提供記錄，以及過程是否實際上運行。
- ☐ 14:00 至 15:00 – 訪談技術經理後，透過抽樣確認資訊服務、使用者和資訊系統在客戶網路中有適當隔離。
- ☐ 15:00 至 15:30 – 訪談選定的程式設計師，來確定其開發工具和軟體庫的使用性。檢查他們是否只使用已授權產品。
- ☐ 15:30 至 16:00 – 審查組織使用的訓練相關資料，以提高對其資訊安全政策和程序的良好認知。檢查線上訓練產品的最新版本。

Q27

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

27 你是一位經驗豐富的 ISMS 稽核小組組長，正指導稽核員關於 ISO/IEC 27001:2022 稽核風險處理過程的訓練。
你目前討論關於風險處理和剩餘風險，並且發放每個學生一張紙上面，有八個與這個主題相關的陳述。 請問下列**哪三個**陳述符合 ISO/IEC 27001:2022 要求？

- ☐ ISO/IEC 27001:2022 要求組織制定風險處理計畫。
- ☐ 簡單地接受風險，是可接受的風險處理選項。
- ☐ 剩餘風險的另一個說法是「留存風險」。
- ☐ 風險擁有者，負責制定組織的資訊安全風險處理計畫
- ☐ 必須按規劃期間，審查剩餘風險的相關計劃。。
- ☐ 該組織運營有記錄的風險處理相關過程。
- ☐ 風險處理並不會永遠100%有效，總是會存在一些剩餘風險
- ☐ 剩餘風險是應用風險處理前的風險。

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

27 你是一位經驗豐富的 ISMS 稽核小組組長，正指導稽核員關於 ISO/IEC 27001:2022 稽核風險處理過程的訓練。
你目前討論關於風險處理和剩餘風險，並且發放每個學生一張紙上面，有八個與這個主題相關的陳述。 請問下列**哪三個**陳述符合 ISO/IEC 27001:2022 要求？

- ✓ ☐ ISO/IEC 27001:2022 要求組織制定風險處理計畫。
- ✓ ☐ 簡單地接受風險，是可接受的風險處理選項。
- ✓ ☐ 剩餘風險的另一個說法是「留存風險」。
- ☐ 風險擁有者，負責制定組織的資訊安全風險處理計畫
- ☐ 必須按規劃期間，審查剩餘風險的相關計劃。。
- ☐ 該組織運營有記錄的風險處理相關過程。
- ☐ 風險處理並不會永遠100%有效，總是會存在一些剩餘風險
- ☐ 剩餘風險是應用風險處理前的風險。

Q28

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

28 在第三方驗證稽核期間，請問受稽核方提供的相關議題清單中。下列**哪四項**屬於 ISO/IEC 27001:2022 管理系統中的「**外部**」議題？

- ☐ 由於削減培訓支出，降低工作人員能力水準
- ☐ 由於政府政策的變化而減少補助金
- ☐ 由於員工假期減少而整體士氣低落
- ☐ 人口老化導致勞動成本上升
- ☐ 為了應對高度通膨而提高利率
- ☐ 由於政府制裁而無法採購關鍵零件
- ☐ 生產力下降與過時生產設備有關
- ☐ 由於管理不善，離職率增加

- ☐ 由於削減培訓支出，降低工作人員能力水準
- ☑ ☐ 由於政府政策的變化而減少補助金
- ☐ 由於員工假期減少而整體士氣低落
- ☑ ☐ 人口老化導致勞動成本上升
- ☑ ☐ 為了應對高度通膨而提高利率
- ☑ ☐ 由於政府制裁而無法採購關鍵零件
- ☐ 生產力下降與過時生產設備有關
- ☐ 由於管理不善，離職率增加

Q29

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

29 你是一位經驗豐富 ISMS 稽核員，使用 ISO/IEC 27001:2022 作為稽核標準進行第三方追查稽核。你正在訪談績效經理，審查組織如何進行監控、量測、分析和評估的一部分作為調查組織。對方提供以下相關回應。請問以下**哪三個**回應**不**符合 ISO/IEC 27001:2022？

- ☐ 每個資訊安全服務都由一組人員監控，並非只有一個人負責這項活動。
- ☐ 資訊安全管理系統的有效性並不令人擔憂；組織的監控活動僅關注在於效率上，因為直接影響組織的獲利能力。
- ☐ 管理審查時，不考慮監測結果的相關趨勢。我們幾個月前提供數據但高階主管告知，他們希望在這些會議上關注其他更具策略性的問題
- ☐ 關於資訊安全服務交付過程，我們不進行任何評估。
- ☐ 確認保存監控活動結果的電腦記錄至少有 5 年
- ☐ 制定檢查日程，並且規定何時應進行例行監測。對於部分的資訊安全服務其檢查每年只需一次。
- ☐ 服務擁有者不監控資訊安全服務的交付，而是交由專業人員組成的中央團隊執行
- ☐ 資訊安全性能分析非常全面，因此不需要對監控結果進行評估

- ☐ 每個資訊安全服務都由一組人員監控，並非只有一個人負責這項活動。
- ☑ ☐ 資訊安全管理系統的有效性並不令人擔憂；組織的監控活動僅關注在於效率上，因為直接影響組織的獲利能力。
- ☑ ☐ 管理審查時，不考慮監測結果的相關趨勢。我們幾個月前提供數據但高階主管告知，他們希望在這些會議上關注其他更具策略性的問題
- ☐ 關於資訊安全服務交付過程，我們不進行任何評估。
- ☐ 確認保存監控活動結果的電腦記錄至少有 5 年
- ☐ 制定檢查日程，並且規定何時應進行例行監測。對於部分的資訊安全服務其檢查每年只需一次。
- ☐ 服務擁有者不監控資訊安全服務的交付，而是交由專業人員組成的中央團隊執行
- ☑ ☐ 資訊安全性能分析非常全面，因此不需要對監控結果進行評估

Q30

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

30 你是一位經驗豐富的 ISMS 稽核員，使用 ISO/IEC 27001:2022 作為稽核準則進行第三方追查稽核。稽核小組組長指派你審查組織風險評鑑過程的任務。
受稽核方組織目前營運兩個資料中心，每個資料中心都有自己的風險登記清冊。你注意到，兩份風險登記清冊包含完全相同的風險描述，但是兩個資料中心的營運經理對剩餘風險的評分方式有顯著差異。
請問你應該採取下列**哪三項**措施？

- ☐ 提出改進機會，向資料中心經理建議對於風險等級採取正確的評估
- ☐ 訪談資料中心經理，確認是否了解如何應用組織的風險接受準則
- ☐ 審查每個資料中心對已識別的 ISMS 風險，所實施控制的程度和相關應用
- ☐ 根據 6.1.2.d.3 提出不符合性，因為每個資料中心的評分方式不同，該組織顯然無法確定剩餘風險的正確等級。
- ☐ 提出改進機會，這表明避免將來對風險進行不同的評分，風險等級應由整個組織決定而不是由單一資料中心決定
- ☐ 記錄兩個資料中心的風險評分差異，但不採取進一步行動。因為對於追查稽核而言，確定差異的原因並不重要
- ☐ 審查任何風險處理計畫，查驗每個資料中心在風險處理上的順序
- ☐ 立即針對 6.1.2b 條文提出不符合性，此條文要求 ISMS 風險評鑑過程產出「一致、有效且可比較的結果」

- ☐ 提出改進機會，向資料中心經理建議對於風險等級採取正確的評估
- ✓ ☐ 訪談資料中心經理，確認是否了解如何應用組織的風險接受準則
- ✓ ☐ 審查每個資料中心對已識別的 ISMS 風險，所實施控制的程度和相關應用
- ☐ 根據 6.1.2.d.3 提出不符合性，因為每個資料中心的評分方式不同，該組織顯然無法確定剩餘風險的正確等級。
- ☐ 提出改進機會，這表明避免將來對風險進行不同的評分，風險等級應由整個組織決定而不是由單一資料中心決定
- ☐ 記錄兩個資料中心的風險評分差異，但不採取進一步行動。因為對於追查稽核而言，確定差異的原因並不重要
- ✓ ☐ 審查任何風險處理計畫，查驗每個資料中心在風險處理上的順序
- ☐ 立即針對 6.1.2b 條文提出不符合性，此條文要求 ISMS 風險評鑑過程產出「一致、有效且可比較的結果」

Q31

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

31 你擔任稽核組長，負責使用 ISO/IEC 27001:2022 作為稽核準則進行第三方追查稽核。您的團隊中有一名培訓中的稽核員，你要求培訓中的稽核員製作一份稽核查檢表，來協助審查組織對文件化資訊的控制。然而在收到稽核查檢表後，你留意到培訓中的稽核員建議的三個稽核軌跡並不適合。

請從下列訓練中的稽核員建議的稽核查檢表中，**刪除**三個不適合的稽核軌跡？

- ☐ 確保能證明 ISMS 有效運作的文件化資訊存在
- ☐ 確保定期審查形成文件的信息，以確保其適合，且足以實現其預期目
- ☐ 確保紙本記錄的儲存方式，是可以防止遺失或損壞的
- ☐ 確保文件化資訊，以工作人員能夠理解的語言發布
- ☐ 確保文件化資訊的存在，以確保組織的 ISMS 過程有按計畫執行
- ☐ 確保組織的資訊安全政策，已酌情提供給感興趣的相關方
- ☐ 確保最高管理階層成員，負責核准文件化資訊修訂之後的相關發佈
- ☐ 確保立即銷毀不再需要支援 ISMS 營運的文件化資訊，以防止其被意外使用

- ☑ ☐ 確保能證明 ISMS 有效運作的文件化資訊存在
- ☐ 確保定期審查形成文件的信息，以確保其適合，且足以實現其預期目
- ☐ 確保紙本記錄的儲存方式，是可以防止遺失或損壞的
- ☐ 確保文件化資訊，以工作人員能夠理解的語言發布
- ☐ 確保文件化資訊的存在，以確保組織的 ISMS 過程有按計畫執行
- ☐ 確保組織的資訊安全政策，已酌情提供給感興趣的相關方
- ☑ ☐ 確保最高管理階層成員，負責核准文件化資訊修訂之後的相關發佈
- ☑ ☐ 確保立即銷毀不再需要支援 ISMS 營運的文件化資訊，以防止其被意外使用

Q32

ISMS ISO_IEC 270... 1 | Section 2 | Section 3 | **Section 4**

32 你是位經驗豐富的 ISMS 稽核組長，帶領一個由兩位有資格稽核小組成員。其中，培訓中的稽核員正在協助團隊使用 ISO/IEC 27001:2022 作為稽核準則進行第二方驗證稽核。你要求培訓中的稽核員提供稽核結果以便將其納入稽核報告中。你在稽核組會議時察覺這些稽核發現缺乏足夠細節，無法識別培訓中稽核員審查的稽核證據。

請選擇你決定應如何繼續的**兩個**選項。

- ☐ 儘管內容不完整，但將她的稽核筆記納入稽核報告中，代表已被稽核的最佳記錄
- ☐ 詢問稽核小組的其他成員，是否發現類似不符合性的相關證據。
- ☐ 在結案會議上，向受稽核方道歉並告知他們，並且告知他們，不幸地整個稽核需要重新安排。
- ☐ 告訴你受稽核方他們員工需要加班，因為部分管理系統必須重新審查。如果他們不留下來，則驗證的決定將自動變為"不建議驗證"
- ☐ 根據稽核期間收集的證據，提出你的驗證建議
- ☐ 告知培訓中的稽核員，她毫無用處，並且不會受到你的未來任何稽核團隊的歡迎。

- ☐ 儘管內容不完整，但將她的稽核筆記納入稽核報告中，代表已被稽核的最佳記錄
- ☑ ☐ 詢問稽核小組的其他成員，是否發現類似不符合性的相關證據。
- ☐ 在結案會議上，向受稽核方道歉並告知他們，並且告知他們，不幸地整個稽核需要重新安排。
- ☐ 告訴你受稽核方他們員工需要加班，因為部分管理系統必須重新審查。如果他們不留下來，則驗證的決定將自動變為"不建議驗證"
- ☑ ☐ 根據稽核期間收集的證據，提出你的驗證建議
- ☐ 告知培訓中的稽核員，她毫無用處，並且不會受到你的未來任何稽核團隊的歡迎。

Q33

ISMS ISO_IEC 270... ion 2 | Section 3 | Section 4 | Section

33 以下**哪四個**關於 ISMS 稽核報告的陳述是**錯誤**的？

- ☐ 稽核報告應該僅表明不符合性
- ☐ 稽核報告應由稽核組長根據稽核組的意見撰寫。
- ☐ 稽核報告應首先發送給組織的最高管理階層，因為其內容可能不體面。
- ☐ 稽核報告應始終由客戶查驗並且註明日期且簽名為"已接受"。
- ☐ 不再需要的稽核報告應使用安全廢棄物處置方式銷毀
- ☐ 除非被特別標記為機密，稽核報告應假定為適合廣泛流通。
- ☐ 稽核報告應由稽核小組成員保留以供日後參考
- ☐ 稽核報告應在同意期限內製作完成

ISMS ISO_IEC 270... ion 2 | Section 3 | Section 4 | Section

33 以下**哪四個**關於 ISMS 稽核報告的陳述是**錯誤**的？

- ☑ 稽核報告應該僅表明不符合性
- ☐ 稽核報告應由稽核組長根據稽核組的意見撰寫。
- ☑ 稽核報告應首先發送給組織的最高管理階層，因為其內容可能不體面。
- ☐ 稽核報告應始終由客戶查驗並且註明日期且簽名為"已接受"。
- ☐ 不再需要的稽核報告應使用安全廢棄物處置方式銷毀
- ☑ 除非被特別標記為機密，稽核報告應假定為適合廣泛流通。
- ☑ 稽核報告應由稽核小組成員保留以供日後參考
- ☐ 稽核報告應在同意期限內製作完成

Q34

ISMS ISO_IEC 270... ion 2 | Section 3 | Section 4 | Section

34 你是位經驗豐富的資訊安全管理系統稽核組長，正在引導一名培訓中的稽核員。你被請求描述跟催稽核的目的。 請問以下**哪一個**選項最能完成下列句子？
跟催稽核的目的是：

- ○ 查證早期稽核中發現的糾正、矯正措施和改進機會的有效性。如果發現重大不符合項則可能簽訂跟催稽核
- ○ 鑑定早期稽核中發現的糾正、矯正措施和改進機會的適當性。如果發現重大不符合性則必須進行跟催稽核
- ○ 確認早期審計中確定的糾正、矯正措施和改進機會的有效性實施。如果發現重大不符合性則建議進行跟催稽核
- ○ 確證早期稽核中發現的糾正、矯正措施和改進機會的有效性。如果發現重大不符合性則必須進行跟催稽核

- V 查證早期稽核中發現的糾正、矯正措施和改進機會的有效性。如果發現重大不符合項則可能簽訂跟催稽核
- ○ 鑑定早期稽核中發現的糾正、矯正措施和改進機會的適當性。如果發現重大不符合性則必須進行跟催稽核
- ○ 確認早期審計中確定的糾正、矯正措施和改進機會的有效性實施。如果發現重大不符合性則建議進行跟催稽核
- ○ 確證早期稽核中發現的糾正、矯正措施和改進機會的有效性。如果發現重大不符合性則必須進行跟催稽核

Q35

ISMS ISO_IEC 270… ion 2 | Section 3 | Section 4 | Section

你正在國際物流組織的出貨部門進行 ISMS 稽核，其為當地醫院和政府機構辦公室等大型組織提供運輸服務。包裹通常包含藥品、生物樣本以及護照和駕駛執照等文件。你注意到公司記錄上顯示大量退件，原因包括標籤地址錯誤，以及有 15% 的情況中，有兩個或多個標明不同的地址標籤。

你正在訪談運輸部經理 (SM)。

你：這些包裹在出貨之前檢查過嗎？

運輸部經理：若有任何明顯損壞物品都會在出貨前由值班人員移除。無法實施正式性檢查其流程，因為利潤不高且不合乎經濟上考量。

你：那在退貨後你們採取什麼措施？

運輸部經理：這些合約大多價值相對較低，因此我們認為簡單地重新列印標籤，並重新發送單一包裹會比實施上檢查更容易方便。

35

你提出不符合性，請問以下哪一個場景中描述了不符合性的原因？

- 8.1 “組織沒有使用有效的流程來確保滿足資料保護的服務要求和法律要求事項。”
- 4.2 “該組織未能了解客戶對於安全運送敏感相關物品的需求。”
- 6.1.3“管理層未能應用適用性聲明包含的風險處理以其相關控制措施。”
- 7.2 “運輸部門的能力值得懷疑。貼上標籤的人員持續性地犯錯。”
- 9.2 “根據運輸經理的說法，內部稽核未能發現大部分貨物貼有錯誤標籤存在的相關問題。”
- 6.2 “該組織沒有與運送顧客持有物相關的資訊安全目標。包裹經常因為標籤不正確而被退回。“

- 8.1 “組織沒有使用有效的流程來確保滿足資料保護的服務要求和法律要求事項。”
- 4.2 “該組織未能了解客戶對於安全運送敏感相關物品的需求。”
- 6.1.3“管理層未能應用適用性聲明包含的風險處理以其相關控制措施。”
- 7.2 “運輸部門的能力值得懷疑。貼上標籤的人員持續性地犯錯。”
- 9.2 “根據運輸經理的說法，內部稽核未能發現大部分貨物貼有錯誤標籤存在的相關問題。”
- 6.2 “該組織沒有與運送顧客持有物相關的資訊安全目標。包裹經常因為標籤不正確而被退回。“

Q36

ISMS ISO_IEC 270... ion 2 | Section 3 | Section 4 | Section

36 你是一位經驗豐富的第三方稽核組長，正在引導培訓中的稽核員。她要求你確認以下每個資訊安全控制措施，並且列入她的最終報告中，應根據 ISO/IEC 27002：2022 的四個控制主題，記錄每個資訊安全控制措施。

請將下列每個控制項與其所屬的控制項主題做類別配對：

應管理對外部網站的訪問，以減少惡意內容的暴露。	
應根據組織的需要、定義和分配資訊安全角色和職責。	
組織應提供一種機制，讓人員透過適當的管道，可及時報告觀察到或可疑的資訊安全事件。	blanks
應制定並適當執行紙張和移動硬碟的桌面淨空規則，以及資訊處理設施的螢幕淨空規則。	

要填寫表格，請按一下要填寫的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，將每個選項拖曳到相應的空白部分。

實體控制　人員控制　組織控制　技術控制

應管理對外部網站的訪問，以減少惡意內容的暴露。	✔ 技術控制
應根據組織的需要、定義和分配資訊安全角色和職責。	✔ 組織控制
組織應提供一種機制，讓人員透過適當的管道，可及時報告觀察到或可疑的資訊安全事件。	✔ 人員控制
應制定並適當執行紙張和移動硬碟的桌面淨空規則，以及資訊處理設施的螢幕淨空規則。	✔ 實體控制

Q37

測試名稱: ISMS ISO_IEC 27001 Lead Auditor practice | ...n 2 | Section 3 | Section 4 | Section 5 | 計時器。考生完成考試的剩餘時間 00:50:2

你是稽核團隊組長，對一家線上保險機構進行第三方稽核。在第一階段，你辨別組織決定 ISO/IEC 27001:2022 中的所有控制措施全部都適用。在第二階段稽核期間，你的稽核團隊發現沒有證據顯示其已經實施適用聲明摘錄中的三項控制措施（5.3 職務區隔、6.1 篩選、7.12 佈纜安全）。

參考控制措施	目標	驅動控制措施			適用的	最後評估日	不適用的理由
		商業風險	法令要求事項	顧客聯繫			
5.3	避免利益衝突	是	不是	不是	是	02/202X	
6.1	篩選人員	是	不是	是	是	02/202X	
7.12	電纜保護	是	是	不是	是	02/202X	

37 根據相關 ISO/IEC 27001:2022 條款，選擇一個選項來正確地描述場景中的不符合性。

- ○ 6.1.3.a “組織未能針對ISO/IEC 27001:2022 附錄 A 5.3、6.1、7.12 中的三項資訊安全控制措施選擇適當的風險處理。”
- ○ 6.1.2.c ”組織沒有進行徹底性的風險評估流程以正確方式識別與控制措施 5.3、6.1 和 7.12 相關的資訊安全風險”。”
- ○ 8.3 “組織未能對與控制措施 5.3、6.1 和 7.12 相關且已識別的風險實施風險處理。”
- ○ 7.5.1.b “組織沒有保留實施控制措施5.3、6.1、7.12 中提到的控制風險處理的文件資訊化證據。”
- ○ 5.3 ”組織沒有分配ISO/IEC 27001:2022附件A中監督安全控制實施的責任。”

- ○ 6.1.3.a “組織未能針對ISO/IEC 27001:2022 附錄 A 5.3、6.1、7.12 中的三項資訊安全控制措施選擇適當的風險處理。”
- ○ 6.1.2.c ”組織沒有進行徹底性的風險評估流程以正確方式識別與控制措施 5.3、6.1 和 7.12 相關的資訊安全風險”。”

✓

- ○ 8.3 “組織未能對與控制措施 5.3、6.1 和 7.12 相關且已識別的風險實施風險處理。”
- ○ 7.5.1.b “組織沒有保留實施控制措施5.3、6.1、7.12 中提到的控制風險處理的文件資訊化證據。”
- ○ 5.3 ”組織沒有分配ISO/IEC 27001:2022附件A中監督安全控制實施的責任。”

Q38

ISMS ISO_IEC 270... < on 2 | Section 3 | Section 4 | Section 5 >

38 你身為 ISMS 稽核小組組長，你代表一家線上零售商，對一家國際物流公司進行第二方稽核。在稽核期間，你的一名團隊成員報告了與 ISO/IEC 27001:2022 附錄 A 的控制措施 5.18（存取權限）相關的不符合性。
並且適用性聲明證明此控制措施的適用性。稽核員發現的證據顯示，過去 3 個月內，離職的 20 名人員伺服器刪除存取權限需要長達 1 週的時間，而政策是要求在他們離開後 24 小時內刪除存取權限。根據 ISO/IEC 27001:2022 的相關條款，選擇**一個**選項，正確地描述此場景中的**不符合性**。

- ○ 6.1.2.c “組織沒有進行足夠徹底的風險評估流程正確性地識別與控制措施 5.18 相關的資訊安全風險。”
- ○ 7.5.1.b “組織沒有監控實施控制措施與風險處理 5.18 的相關文件化資訊證據”
- ○ 8.3 “組織未能有效實施與已識別風險與控制措施5.18 相關的風險處理。”
- ○ 5.3 “組織未能分配責任來確保執行控制措施 5.18 時必需的風險處理。”
- ○ 6.1.3.a “組織未能為 ISO 27001:2022 附錄 A 中的資訊安全控制措施 5.18 選擇適當的風險處理方法。”

- ○ 6.1.2.c “組織沒有進行足夠徹底的風險評估流程正確性地識別與控制措施 5.18 相關的資訊安全風險。”
- ○ 7.5.1.b “組織沒有監控實施控制措施與風險處理 5.18 的相關文件化資訊證據”

- ✓ ○ 8.3 “組織未能有效實施與已識別風險與控制措施5.18 相關的風險處理。”

- ○ 5.3 “組織未能分配責任來確保執行控制措施 5.18 時必需的風險處理。”
- ○ 6.1.3.a “組織未能為 ISO 27001:2022 附錄 A 中的資訊安全控制措施 5.18 選擇適當的風險處理方法。”

Q39

ISMS ISO_IEC 270... | ...n 2 | Section 3 | Section 4 | **Section 5**

39 你是稽核組長，計畫今年稍早完成第三方追查稽核後再進行跟催稽核。他們決定檢閱修正之前，將先查驗需要矯正措施的不符合性。根據下列的描述，哪**四項**是針對追查中，發現不符合性所採取相關的**矯正措施**？

- ☐ 由於錯過預定的管理審查日期，總經理每年優先安排在兩次的特定日期。
- ☐ 客戶資料服務合約中，缺少簽名被新增。
- ☐ 產品運輸的文件流程，並未反映出貨團隊如何進行此項活動，因此重新編寫流程進行相關的培訓。
- ☐ 硬碟 HD302 的顏色編碼為綠色（可用）而不是紅色（待銷毀），其已從系統中刪
- ☐ 日期錯誤的新網路交換器採購訂單，已修正。
- ☐ 該組織未能維持其適用性聲明，將其更新的責任重新分配給技術總監。
- ☐ 尚未與新系統同時發送給客戶的軟體安裝指南，已後續寄發。
- ☐ 針對不依照規定程序，進行備份的資料中心工作人員進行再次訓練。

- ✓ ☐ 由於錯過預定的管理審查日期，總經理每年優先安排在兩次的特定日期。
- ☐ 客戶資料服務合約中，缺少簽名被新增。
- ✓ ☐ 產品運輸的文件流程，並未反映出貨團隊如何進行此項活動，因此重新編寫流程，並對團隊進行相關的培訓。
- ☐ 硬碟 HD302 的顏色編碼為綠色（可用）而不是紅色（待銷毀），其已從系統中刪除。
- ☐ 日期錯誤的新網路交換器採購訂單，已修正。
- ✓ ☐ 該組織未能維持其適用性聲明，將其更新的責任重新分配給技術總監。
- ☐ 尚未與新系統同時發送給客戶的軟體安裝指南，已後續寄發。
- ✓ ☐ 針對不依照規定程序，進行備份的資料中心工作人員進行再次訓練。

ISMS ISO_IEC 270... < on 2 | Section 3 | Section 4 | Section 5 >

40 你是一位經驗豐富的 ISMS 稽核組長引導著培訓中的稽核員。她詢問你稽核報告中不符合性的分級。你將根據 ISO 19011，請她選出以下**哪四個錯誤**的陳述，來決定測試她的相關知識。

- ☐ 受稽核方始終負責確定不符合性的分級標準。
- ☐ 重大不符合性可能需要現場跟進。
- ☐ 無論使用何種分級系統，為解決主要不符合性發現而採取的行動，通常比為解決次要的不符合性問題而採取的行動更來得更有實質性。
- ☐ 不符合性必須使用「主要」或「次要」術語進行分級。
- ☐ 非常輕微的不符合性，應重新評級為改進機會。
- ☐ 不符合性的分級必須在結案會議中向受稽核方解釋。
- ☐ 不符合性可以分級以顯示其重要性。
- ☐ 若干個次要不符合性可歸為一個主要不符合性。

- ✓ ☐ 受稽核方始終負責確定不符合性的分級標準。
- ☐ 重大不符合性可能需要現場跟進。
- ☐ 無論使用何種分級系統，為解決主要不符合性發現而採取的行動，通常比為解決次要的不符合性問題而採取的行動更來得更有實質性。
- ✓ ☐ 不符合性必須使用「主要」或「次要」術語進行分級。
- ✓ ☐ 非常輕微的不符合性，應重新評級為改進機會。
- ✓ ☐ 不符合性的分級必須在結案會議中向受稽核方解釋。
- ☐ 不符合性可以分級以顯示其重要性。
- ☐ 若干個次要不符合性可歸為一個主要不符合性。